

KRİPTOQRAFIYA KURSU

Mühazirə 25

TLS/SSL Protokolu

Bu mühazirə TLS/SSL protokolunun tarixini, arxitekturasını, əl sıxma protokolunu, yazı protokolunu, şifrə dəstlərini, TLS 1.3-də yenilikləri və irəli məxfilik anlayışını əhatə edir.

September 23, 2026

Contents

1	Mühazirənin məqsədləri	3
2	Giriş	3
3	TLS Arxitekturası və Alt Protokolları	4
3.1	Yazı Protokolu	5
3.2	Rekord Paketinin Anatomiyası	5
3.3	Ön şərt 1: Şifrə Dəstləri	6
3.3.1	Tərif və Struktur Təkamülü	6
3.3.2	Klassik TLS Şifrə Dəstinin Komponentləri	6
3.3.3	TLS 1.3-də Sadələşdirmə və AEAD Məcburiyyəti	6
3.3.4	TLS 1.3 açar cədvəli üçün minimum model	7
3.4	Ön şərt 2: İrəli Məxfilik (Forward Secrecy – FS)	7
3.4.1	Kriptografik Tərfi	7
3.4.2	FS-in İş Mexanizmi və Əhəmiyyəti	7
3.4.3	Alqoritmik Təminat və TLS-də Tətbiqi	8
3.5	Əl Sıxma Protokolu	8
4	TLS 1.2 Əl Sıxması	8
4.1	ClientHello	8
4.2	ServerHello	9
4.3	Sertifikat Göndərilməsi (<i>Certificate</i>)	10
4.4	ServerKeyExchange (lazım olduqda)	10
4.5	ServerHelloDone	10
4.6	ClientKeyExchange	10
4.7	ChangeCipherSpec	10
4.8	Finished	10
5	TLS 1.3 Əl Sıxması	11
5.1	Fundamental Arxitektur Fərqlər	11
5.2	Müştəri Salamı (ClientHello)	12
5.3	Server Salamı (ServerHello) və Şifrəli Mesajlar	12
6	0-RTT (Sıfır Gedış-Gəliş Müddəti) Rejimi	12
6.1	İş Prinsipi	12
6.2	Kritik Təhlükəsizlik Riskləri	13
7	TLS Protokoluna Qarşı Tarixi Hücumlar və Təhlükəsizlik Problemləri	13
7.1	POODLE Hücumu (2014)	14
7.2	BEAST Hücumu (2011)	14
7.3	CRIME Hücumu (2012)	14
7.4	Heartbleed Boşluğu (2014)	15
7.5	Logjam (2015) və FREAK (2015) Hücumları	15
8	Praktik Təvsiyələr	16

9	Nümunə məsələlər və çalışmalar	17
10	Müəllim üçün cavab açarı	18
11	Xülasə	19

1 Mühazirənin məqsədləri

Bu mühazirəni bitirdikdən sonra tələbələr:

- TLS Rekord (*Record*) və əl sıxma (*Handshake*) qatlarının vəzifələrini təqdim edilən protokol trafiki izində (*packet trace*) fərqləndirməyi (Stallings, 2017);
- TLS 1.2 və TLS 1.3 şifrə dəstləri (*cipher suite*) semantikasını, açar cədvəlini (*key schedule*) və irəli məxfilik (*forward secrecy*) şərtlərini müqayisə etməyi (Ferguson et al., 2010; Rescorla, 2018);
- TLS 1.2 və 1.3 əl sıxma mesajlarını autentifikasiya və açar törədilməsi məqsədlərinə görə izləməyi (Paar et al., 2024);
- sertifikat/yol yoxlaması xətasını protokol xətasından fərqləndirməyi;
- 0-RTT məlumatı üçün təkrar icra (*replay attack*) riskini müəyyən edib təhlükəsiz qəbul siyasəti təklif etməyi bacaracaqlar (Rescorla, 2018).

Kurs xəritəsi və terminologiya kanonu

Əvvəl: 24-cü mühazirədə X.509 sertifikat zənciri və yolun doğrulanması mexanizmləri təhlil edildi.

İndi: TLS həmin etibar qərarını rekord qatının qorunması və autentifikasiya olunmuş açar razılaşdırılması ilə birləşdirir.

Sonra: 26-cı mühazirə qorumanı tətbiq bağlantısından şəbəkə səviyyəsindəki IPsec/VPN modelinə keçirəcəkdir.

Kanon: *şifrə dəsti (cipher suite); açar cədvəli (key schedule); irəli məxfilik (forward secrecy, FS); sessiya açarı (session key); 0-RTT erkən məlumatı (0-RTT early data).*

2 Giriş

Müasir internet infrastrukturunda təhlükəsiz və məxfi rabitənin təmin edilməsi üçün ən geniş yayılmış protokollardan biri TLS-dir¹. Gündəlik istifadə etdiyimiz HTTPS², e-poçt protokolları (IMAPS³, SMTPS⁴), VPN⁵ sistemləri və bir çox paylanmış tətbiqlər məhz TLS-in təmin etdiyi kriptografik təhlükəsizlik zəmanətlərinə əsaslanır. Bu mühazirədə TLS protokolunun daxili arxitekturasını, şəbəkə layihələndirilməsini, iş prinsiplərini, müasir hücum növlərinə qarşı dayanıqlığını və SSL-dən TLS 1.3-ə qədər olan tarixi təkamül prosesini dərinlən təhlil edəcəyik.

¹TLS (*Transport Layer Security* — Nəqliyyat Qatının Təhlükəsizliyi): Şəbəkə üzərindən ötürülən məlumatların konfidensiallığını, bütövlüyünü və autentifikasiyasını təmin edən kriptografik protokol.

²HTTPS (*Hypertext Transfer Protocol Secure*): HTTP protokolunun TLS vasitəsilə şifrələnmiş təhlükəsiz versiyası (TCP 443).

³IMAPS (*Internet Message Access Protocol Secure*): Məktubların oxunması üçün IMAP protokolunun TLS ilə qorunan forması (TCP 993).

⁴SMTPS (*Simple Mail Transfer Protocol Secure*): E-poçt göndərilməsi üçün SMTP protokolunun TLS ilə qorunan forması (TCP 465/587).

⁵VPN (*Virtual Private Network* — Virtual Şəxsi Şəbəkə): Açıq şəbəkələr üzərində şifrələnmiş təhlükəsiz tunel yaradan texnologiya.

Metodoloji Araşdırma Sualları

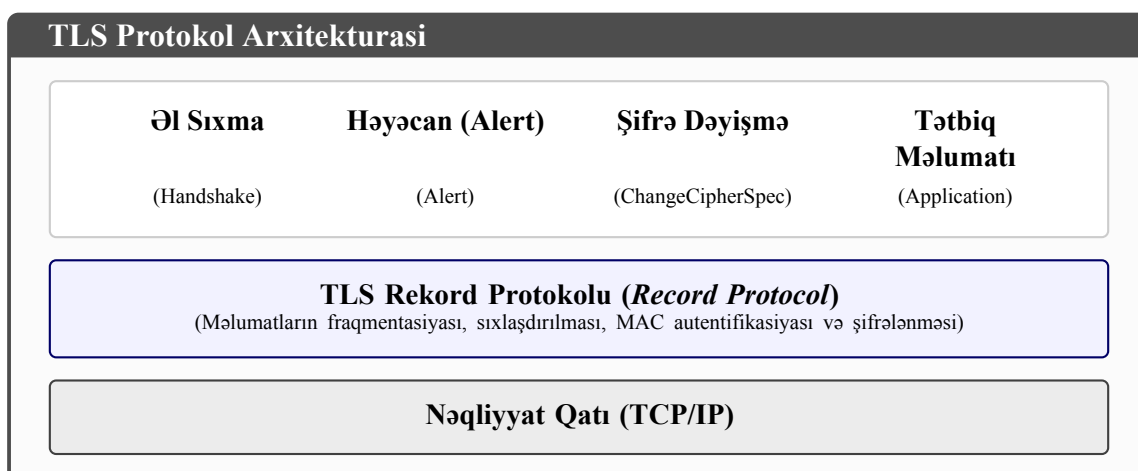
- Tarixi SSL^a protokolları ilə müasir TLS protokolları arasında hansı fundamental və təhlükəsizlik fərqləri var?
- TLS əl sıxması (*handshake*) kriptografik olaraq sessiya açarlarını necə generasiya edir?
- Rekord protokolu nədir, verilənləri necə fraqmentləşdirir və şifrələyir?
- Şifrə dəstləri (*cipher suites*) daxilində hansı primitivlər (autentifikasiya, açar mübadiləsi, simmetrik şifrələmək və həşləmə) kodlaşdırılır?
- TLS 1.3 versiyasında gecikmə müddətini azaltmaq üçün hansı struktur dəyişiklikləri edilmişdir?
- 0-RTT^b rejimi nədir və bu rejim hansı kritik təhlükəsizlik boşluqlarına yol açabilir?
- İrəli məxfilik (Forward Secrecy - FS) nə deməkdir və uzunmüddətli kök açarların kompromat olunması anında keçmiş sessiyaları necə qoruyur?

^aSSL (*Secure Sockets Layer* — Təhlükəsiz Soketlər Qatı): Netscape tərəfindən 1990-cı illərdə yaradılmış və veb trafiki şifrələmək üçün istifadə olunmuş ilk kriptografik protokoldur. Təhlükəsizlik zəifliklərinə görə 2015-ci ildə (RFC 7568) istifadədən tam çıxarılmış və yerini TLS-ə vermişdir.

^b0-RTT (*Zero Round-Trip Time* — Sıfır gediş-gəliş müddəti): TLS 1.3 protokolunda əvvəllər qoşulmuş tərəflərin təkrar əl sıxması (*handshake*) gözləmədən, ilk şəbəkə paketində tətbiq məlumatlarını (*early data*) şifrələyərək göndərməsinə imkan verən rejimdir.

3 TLS Arxitekturası və Alt Protokolları

TLS protokolu funksional olaraq iki əsas qatdan (laydan) və dörd alt protokoldan ibarət mürəkkəb bir memarlığa malikdir (Stallings, 2017). Yuxarı qat tərəflərin razılaşdırılması və idarəetmə mexanizmlərinə cavabdeh olduğu halda, aşağı qat birbaşa məlumatın təhlükəsiz daşınmasını təmin edir.



Şəkil 1: TLS Protokol Arxitekturası və Qat Strukturunun Bölünməsi

3.1 Yazı Protokolu

Rekord protokolu TLS memarlığının ən aşağı qatını təşkil edir. O, yuxarı qatdakı tətbiq və idarəetmə protokollarından gələn bütün məlumatların kapsullaşdırılması, bütövlüyünün yoxlanılması və şifrələnməsi üçün unifikasiya olunmuş təhlükəsiz ötürmə interfeysi təmin edir (Paar et al., 2024).

Rekord protokolunun ardıcıl fəaliyyət algoritmi:

- Fraqmentasiya (Fragmentation):** Yuxarı qatdan gələn böyük həcmli məlumatlar idarə edilə bilən konseptual bloklara (maksimum 2^{14} bayt və ya 16 KB) bölünür;
- Sıxlaşdırma (Compression):** TLS 1.2 rekord sıxlaşdırmasını nəzəri olaraq razılaşdırma bildirdi; grafik profillər CRIME riskinə görə onu söndürür. TLS 1.3 rekord sıxlaşdırmasını müəyyən etmir. BREACH isə HTTP səviyyəli sıxlaşdırma ilə bağlı ayrıca riskdir;
- Autentifikasiya:** Məlumatın bütövlüyünü təmin etmək üçün hər bir bloka Mesaj Autentifikasiya Kodu (MAC) əlavə edilir (müasir AEAD rejimlərində bu proses şifrələmə ilə eyni anda icra olunur);
- Şifrələmə:** Razılaşdırılmış simmetrik sessiya açarı vasitəsilə məlumat bloku məxfiliyi qorumaq məqsədilə şifrələnir;
- Ötürmə (Transmission):** Hazır olan TLS Rekord paketi aşağıda yerləşən nəqliyyat qatına (adətən TCP) təslim edilir.

3.2 Rekord Paketinin Anatomiyası

Nəzəri baxımdan şəbəkə səviyyəsində ötürülən hər bir TLS açıq-mətn paketi sabit başlıq və dəyişən ölçülü faydalı yük hissəsindən ibarət olur. Paketin bayt paylanması və daxili strukturu aşağıdakı kimidir:

Cədvəl 1: TLS Rekord Başlığının Bayt Strukturu

Sahə Adı	Ölçüsü	Nəzəri Funksiyası
Məzmun tipi	1 bayt	Paketin hansı üst protokola aid olduğunu bildirir.
Protokol Versiyası (<i>Versiya</i>)	2 bayt	İstifadə olunan TLS versiyasının majör/minör nömrəsi.
Uzunluq	2 bayt	Başlıqdan sonra gələn fraqmentin bayt olaraq ölçüsü.
Fraqment	Maks 16 KB	Şifrələnmiş məlumat və ya idarəetmə mesajları.

TLS 1.2 və əvvəlki versiyalarda başlığın məzmun tipi sahəsi aşağıdakı protokol növlərini bir-başa göstərir. TLS 1.3-də qorunan yazının xarici tipi `application_data`, `legacy_record_version` sahəsi isə `0x0303` olur; həqiqi daxili tip şifrələnmiş `TLSInnerPlaintext` sonunda yerləşir (Rescorla, 2018).

Protokoldaxili məzmun tipi identifikatorları:

- `0x14 (20)`: `ChangeCipherSpec` – TLS 1.2-də tərəflərin növbəti mesajlar üçün razılaşdırılmış mühafizəyə keçdiyini bildirir. TLS 1.3-də açar keçidi bu mesajla idarə edilmir; uyğunluq məqsədli dummy `ChangeCipherSpec` qəbul edilə və nəzərə alınmaya bilər;
- `0x15 (21)`: `Alert` – Bağlantı zamanı yaranan xətalara, xəbərdarlıqlara və ya bağlantanın qəfil kəsilməsi (fatal) mesajlarını daşıyır;

- 0x16 (22): 1 sıxma – Sessiyanın ilkin qurulması üçün tələb olunan əl sıxma mesajlaşmasını ötürür;
- 0x17 (23): ApplicationData – İstifadəçinin real şifrələnmiş trafikini (məsələn, HTTP mətni, fayl transferi) daşıyır.

3.3 Ön şərt 1: Şifrə Dəstləri

3.3.1 Tərif və Struktur Təkamülü

Şifrə dəsti (*cipher suite*) — TLS bağlantısı zamanı tərəflərin konfidensiallıq, bütövlük və autentifikasiya ehtiyaclarını qarşılamaq üçün istifadə edəcəyi kriptografik alqoritmlər toplusudur (Ferguson et al., 2010).

Protokolun təkamül prosesində şifrə dəstlərinin adlandırılma formatı köklü şəkildə dəyişmişdir:

- **TLS 1.2 və Əvvəlki Standart:** TLS_[Açar_Mübadiləsi]_WITH_[Şifrələmə]_[İnteqrasiya]
Nümunə: TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
Bu formatda bütün kriptografik mərhələlər tək bir sətirdə birləşirdi.
- **TLS 1.3 Standartı:** TLS_[AEAD_Şifrələmə]_[Hash]
Nümunə: TLS_AES_256_GCM_SHA384
Açar mübadiləsi və imza alqoritmləri bu bəyannamədən ayrılaraq müstəqil genişləndirmələrə keçirilmişdir.

3.3.2 Klassik TLS Şifrə Dəstinin Komponentləri

TLS 1.2 və əvvəlki versiyaların klassik şifrə dəsti adı dörd funksional qrupu əlaqələndirirdi (Stallings, 2017):

1. **Açar Mübadiləsi:** RSA açar ötürülməsində ilkin əsas sirr şifrələnib ötürülür, DHE/ECDHE-də isə tərəflər ortaq sirri açıq paylardan hesablayır;
2. **Autentifikasiya:** Serverin (və ya müştərinin) rəqəmsal kimliyini təsdiqləyir (məsələn, RSA və ya ECDSA);
3. **Simmetrik şifrələmə:** Əsas verilənlər axınını şifrələyir (məsələn: AES-GCM, AES-CBC, ChaCha20);
4. **PRF/MAC üçün heş:** TLS 1.2 dəstindən asılı olaraq açar törətmə və HMAC üçün istifadə olunur; AEAD dəstində rekord bütövlüyünü autentifikasiya teqi təmin edir.

3.3.3 TLS 1.3-də Sadələşdirmə və AEAD Məcburiyyəti

TLS 1.3 əsas təsviri beş şifrə dəsti müəyyən edir və yalnız **AEAD**, yəni əlaqəli verilənlərlə autentifikasiyalı şifrələmə rejimlərini dəstəkləyir (Rescorla, 2018). Dəstin adındakı heş qeyd üçün ayrıca MAC deyil; HKDF açar cədvəli və əl sıxma transkripti üçün istifadə olunur:

- TLS_AES_128_GCM_SHA256 — Standart və ən çox istifadə olunan səmərəli dəst;
- TLS_AES_256_GCM_SHA384 — AES-256-GCM və SHA-384 əsaslı dəst;

- TLS_CHACHA20_POLY1305_SHA256 — Mobil və aparat sürətləndiricisi (AES-NI) olmayan cihazlar üçün optimal seçim;
- TLS_AES_128_CCM_SHA256 — resursları məhdud olan əşyaların interneti (IoT) ekosistemi üçün;
- TLS_AES_128_CCM_8_SHA256 — IoT mühiti üçün qısaldılmış autentifikasiya təqinə malik spesifik alt-variant.

TLS 1.3-də autentifikasiya və açar mübadiləsi mexanizmləri bu siyahıdan kənar idarə olunduğu üçün, sistem mühəndisləri imza alqoritmlərini (RSA-PSS, ECDSA, Ed25519) müstəqil şəkildə konfiqurasiya edirlər.

3.3.4 TLS 1.3 açar cədvəli üçün minimum model

Əl sıxma mərhələsini öyrənməzdən əvvəl dörd əsas səviyyəni fərqləndirmək lazımdır: PSK-dan əldə edilə bilən *erkən sirr* (*early secret*), (EC)DHE nəticəsi daxil olduqdan sonra formalaşan *əl sıxma sirri* (*handshake secret*), daha sonra *əsas sirr* (*master secret*) və transkriptdən asılı olan *əl sıxma/tətbiq trafik sirləri*. İlkin (EC)DHE nəticəsi birbaşa rekord açarı kimi istifadə edilmir; HKDF açar cədvəli kontekst və transkript heş qiymətini nəzərə almaqla müvafiq açar və IV (*initialization vector*) materiallarını törədir.

3.4 Ön şərt 2: İrəli Məxfilik (Forward Secrecy – FS)

3.4.1 Kriptografik Tərif

Tərif 3.1 (İrəli Məxfilik). *İrəli məxfilik (FS)* — *serverin uzunmüddətli asimmetrik gizli açarı gələcəkdə hücumçular tərəfindən ələ keçirilsə belə, keçmişdə həmin serverlə qurulmuş sessiyaların şifrəli trafikinin deşifrə oluna bilməməsi xüsusiyyətidir (Diffie and Hellman, 1976).*

3.4.2 FS-in İş Mexanizmi və Əhəmiyyəti

Əgər şəbəkə infrastrukturunda FS arxitekturası tətbiq edilməzsə (məsələn, açar mübadiləsi üçün yalnız statik RSA istifadə olunarsa):

- Hücumçu hədəf serverin şifrəli şəbəkə trafikini illərlə passiv şəkildə qeydə ala bilər;
- İllər sonra server fiziki olaraq ələ keçirildikdə və ya məhkəmə qərarı ilə serverin əsas gizli açarı tapıldıqda, hücumçu arxivdəki bütün keçmiş gizli yazışmaları geriye dönük olaraq tamamilə deşifrə edər.

Bağlantıda FS aktiv edildikdə isə mexanizm belə işləyir:

- Hər bir unikal sessiya üçün operativ yaddaşda (RAM) tamamilə unikal, müvəqqəti açar cütləri generasiya olunur;
- Sessiya bağlandığı an bu keçici açarlar operativ yaddaşdan birdəfəlik silinir;
- Gələcəkdə serverin ana açarı oğurlansa belə, həmin açar keçmiş sessiya açarlarını riyazi olaraq bərpa edə bilmir, çünki keçmiş açarlar ana açardan törəməmişdir.

3.4.3 Alqoritmik Təminat və TLS-də Tətbiqi

TLS kontekstində irəli məxfilik adətən efemer Diffi–Hellman paylaşımının açar cədvəlinə daxil edilməsi ilə əldə olunur:

- **DHE:** Tam ədədlər qrupu üzərində hər bağlantıya özəl müvəqqəti parametrlər formalaşdırır;
- **ECDHE:** Elliptik əyrilər kriptografiyası əsasında həm sürətli, həm də FS təminatlı açar mübadiləsi aparır.

FS təmin etməyən köhnə rejimlər: RSA açar ötürülməsində müştəri ilkin əsas sirri serverin daimi RSA açıq açarı ilə şifrələyir. Statik DH-də isə tərəflərdən birinin uzunmüddətli DH gizli açarı qeydə alınmış açıq paylarla birlikdə keçmiş ortaqların hesablanması imkan verə bilər. Bunlar fərqli mexanizmlərdir, lakin uzunmüddətli açarın sonrakı ələ keçirilməsi baxımından eyni irəli məxfilik problemini yaradır.

TLS 1.2-də irəli məxfilik DHE/ECDHE dəstəsinin seçilməsindən asılı idi. TLS 1.3 statik RSA və statik DH açar mübadiləsini çıxarıb; sertifikatlı tam əl sıxma və psk_dhe_ke rejimi (EC)DHE-ni açar cədvəlinə daxil edir. Bununla belə, yalnız PSK-a əsaslanan psk_ke rejimi və 0-RTT erkən məlumat irəli məxfilik vermir. Buna görə “TLS 1.3 həmişə FS-dir” iddiası düzgün deyil (Rescorla, 2018).

3.5 Əl Sıxma Protokolu

Əl sıxma protokolu tətbiq məlumatlarının mübadiləsi başlamazdan əvvəl müştəri və server arasında təhlükəsiz kriptografik kanal yaradan ən mürəkkəb alt protokoldur (Stinson and Paterson, 2018).

Əsas fundamental funksiyaları:

- **Tərəflərin Autentifikasiyası:** Rəqəmsal sertifikatlar vasitəsilə serverin (bəzən həm də müştərinin) həqiqiliyi yoxlanılır;
- **Kriptografik Alqoritmlərin Razılaşdırılması:** Hər iki tərəfin dəstəklədiyi və sənaye tərəfindən qəbul edilən ən təhlükəsiz şifrə dəstəsinin (*cipher suite*) seçilməsi;
- **Simmetrik Açarların Yaradılması:** Asimmetrik kriptografiya (məsələn, DH və ya ECDH) vasitəsilə tərəflər arasında məlumat şifrələməsində istifadə olunacaq müvəqqəti simmetrik sessiya açarlarının təhlükəsiz şəkildə generasiya edilməsi.

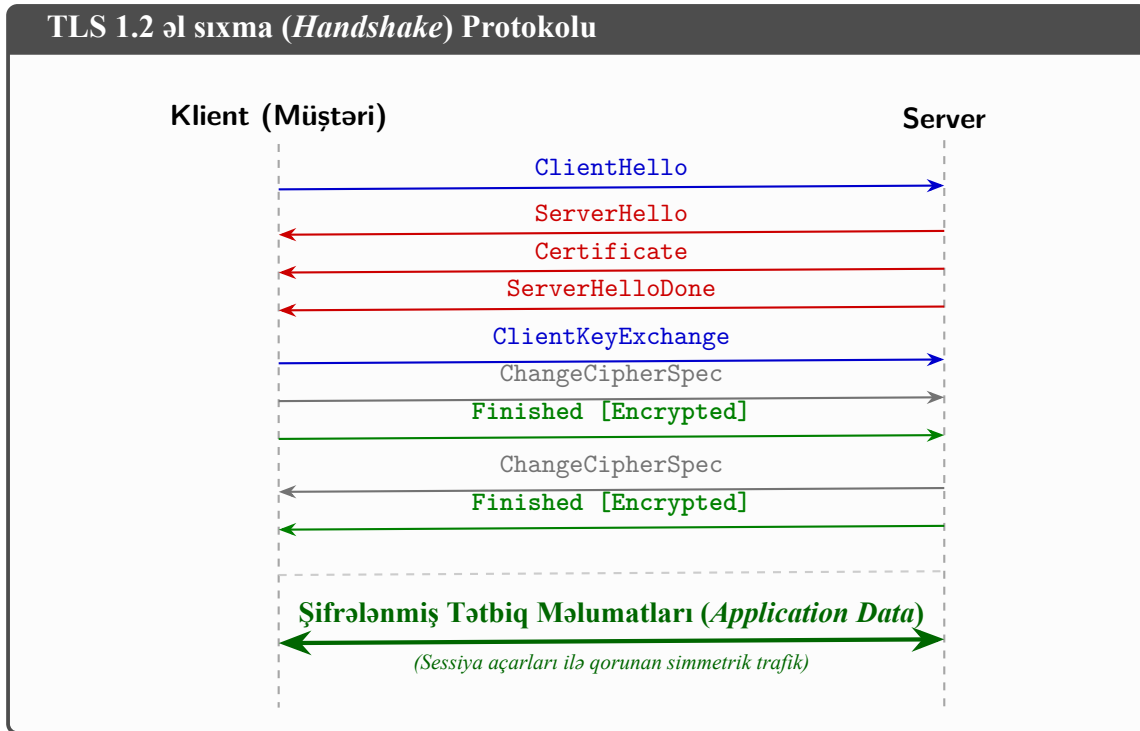
4 TLS 1.2 Əl Sıxması

Tipik tam TLS 1.2 əl sıxması müştərinin tətbiq məlumatını göndərməsindən iki gediş-gəliş (2 RTT) tələb edir (Rescorla, 2018).

4.1 ClientHello

Müştəri serverə aşağıdakı məlumatları göndərir (Ferguson et al., 2010):

- **Versiya (*Version*):** Müştərinin (klientin) dəstəklədiyi ən yüksək TLS versiyası;
- **Təsadüfi dəyər (*Random*):** Klient tərəfindən generasiya olunan 32 baytlıq təsadüfi dəyər;



Şəkil 2: TLS 1.2 tam əl sıxması (*Full Handshake*) və şifrələnmiş kanala keçid ardıcılığı.

- **Sessiya identifikatoru (*Session ID*):** Yeni əlaqə yaradıldıqda sıfır (0), təkrar bərpa edildikdə isə əvvəlki id qiyməti;
- **Şifrə dəstləri (*Cipher Suites*):** Müştərinin dəstəklədiyi kriptografik şifrə dəstlərinin prioritet sırası ilə siyahısı;
- **Sıxlaşdırma metodları (*Compression Methods*):** Müştərinin dəstəklədiyi sıxlaşdırma alqoritmləri (TLS 1.3-də təhlükəsizlik risklərinə görə ləğv edilmişdir);
- **Genişlənmələr (*Extensions*):** Əlavə imkanlar və parametrlər (məsələn, SNI, ALPN, dəstəklənən qruplar və s.).

4.2 ServerHello

Server, klientin sorğusuna cavab olaraq aşağıdakı parametrləri göndərir:

- **Versiya (*Version*):** Klientin təklif etdiyi siyahıdan seçilmiş TLS versiyası;
- **Təsadüfi dəyər (*Random*):** Server tərəfindən generasiya olunan (klientin təsadüfi dəyərindən müstəqil) 32 baytlıq dəyər;
- **Sessiya identifikatoru (*Session ID*):** Təyin olunmuş və ya bərpa edilən sessiyanın identifikatoru;
- **Şifrə dəsti (*Cipher Suite*):** Klientin siyahısından seçilmiş vahid şifrə dəsti;
- **Sıxlaşdırma metodu (*Compression Method*):** Seçilmiş sıxlaşdırma alqoritmi (TLS 1.2 və öncəki versiyalarda);
- **Genişlənmələr (*Extensions*):** Təsdiqlənmiş və seçilmiş əlavə parametrlər.

4.3 Sertifikat Göndərilməsi (*Certificate*)

Server öz zəncirvari sertifikatını (server sertifikatı və tələb olunduqda aralıq CA sertifikatlarını) göndərir (Stallings, 2017). Sertifikatın əsas tərkib hissələri:

- Serverin açıq açarı (*public key*);
- Serverin domen adı — Əsas Ad (*Common Name — CN*) və ya Subyektin Alternativ Adı (*Subject Alternative Name — SAN*);
- Sertifikat Mərkəzinin (CA) rəqəmsal imzası;
- Sertifikatın etibarlılıq müddəti (*Validity Period*).

4.4 ServerKeyExchange (lazım olduqda)

DHE və ECDHE kimi müvəqqəti (*ephemeral*) açar mübadiləsi metodları istifadə edildikdə server əlavə efemer parametrləri göndərir (Ferguson et al., 2010):

- Diffi-Hellman parametrləri (p , g və ya eliptik əyri parametrləri);
- Serverin efemer Diffi-Hellman açıq açarı;
- Göndərilən parametrlərin rəqəmsal imzası (serverin uzunmüddətli özəl açarı ilə imzalanır).

4.5 ServerHelloDone

Server, əl sıxmanın ilk mərhələsinin (server tərəfinin mesajlarının) yekunlaşdığını bildirir.

4.6 ClientKeyExchange

Klient, simmetrik açarın törədilməsi üçün tələb olunan parametri göndərir (Paar et al., 2024):

- **RSA rejimi üçün:** Serverin açıq açarı ilə şifrələnmiş ilkin əsas sirt (*Pre-Master Secret*);
- **DHE/ECDHE rejimi üçün:** Klientin efemer Diffi-Hellman açıq açarı.

4.7 ChangeCipherSpec

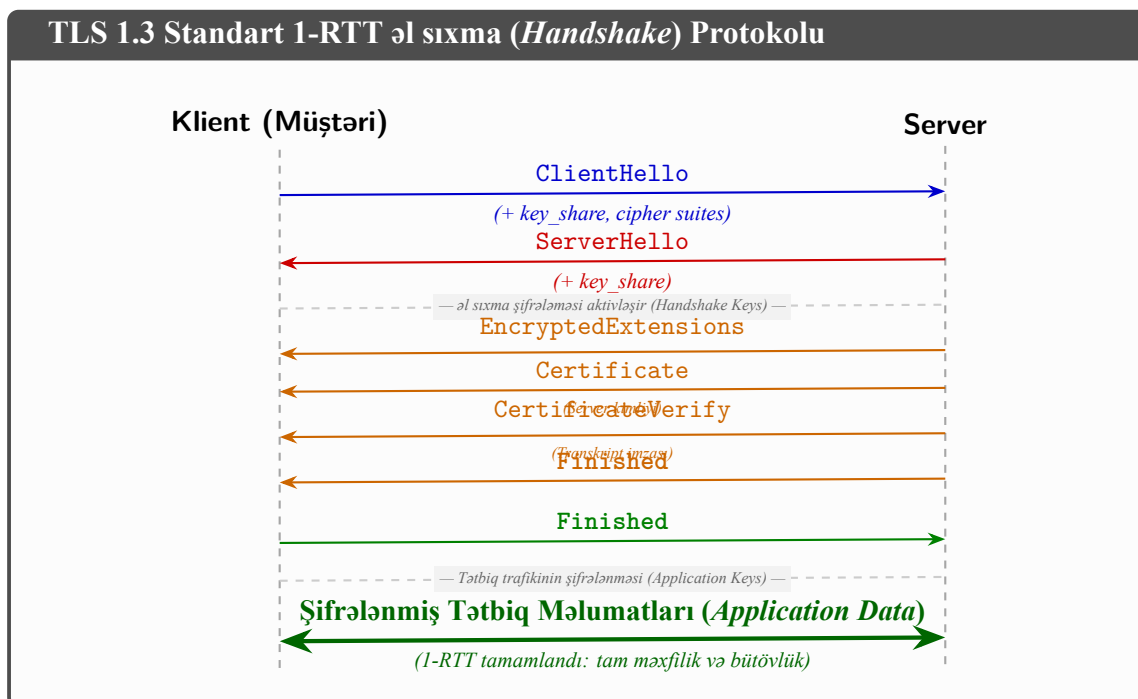
Bu mesaj, tərəflərin növbəti mərhələdən etibarən razılaşdırılmış simmetrik şifrələməyə və bütövlük qorunmasına keçəcəyini xəbərdar edən signaldır.

4.8 Finished

Finished mesajı yeni razılaşdırılmış açarlarla qorunan ilk əl sıxma mesajıdır. Onun *verify_data* sahəsinin qiyməti əsas sirtdən (*Master Secret*) və həmin ana qədər mübadilə edilmiş bütün əl sıxma transkriptinin heş dəyərindən Pseudo-Random Function (PRF) vasitəsilə hesablanır. Bu mexanizm sayəsində qarşı tərəf həm açar razılaşmasının dəqiqliyini, həm də transkriptin bütövlüyünü (ötürülmə zamanı dəyişdirilmədiyini) yoxlayır.

5 TLS 1.3 ƏL Sixması

TLS 1.3 tam əl sixmada müştərinin tətbiq məlumatını göndərməsinədək gecikməni tipik TLS 1.2-dəki 2 RTT-dən 1 RTT-yə endirir (Rescorla, 2018).



Şəkil 3: TLS 1.3 protokolunda 1-RTT əl sixma mexanizmi və mərhələli şifrələmə keçidləri.

5.1 Fundamental Arxitektural Fərqlər

TLS 1.3 spesifikasiyasında əvvəlki versiyalarla müqayisədə edilən əsas struktur dəyişiklikləri aşağıdakılardır:

1. **Mesajların unifikasiyası:** TLS 1.2-də mövcud olan **ServerKeyExchange** və **ServerHelloDone** mesajları tamamilə ləğv edilmiş, onların funksionallığı birbaşa **ServerHello** və genişlənmələrin (*extensions*) daxilinə inteqrasiya olunmuşdur;
2. **Açar vəziyyətinə keçid mexanizmi:** TLS 1.3-də **ChangeCipherSpec** mesajı artıq şifrələmə vəziyyətini dəyişmir. Bu mesaj bəzi şəbəkə avadanlıqları ilə (*middleware*) geriye uyğunluğu qorumaq məqsədilə fiktiv (*dummy*) signal kimi göndərilə bilər və qəbuledici tərəfindən nəzərə alınmır;
3. **Açar mübadiləsinin optimallaşdırılması:** Klient hələ ilk mesajda (**ClientHello**) dəstəklədiyi Diffi-Hellman qrupları üçün öz efemer açıq açar payını (*key_share*) göndərir. Beləliklə, alqoritmin seçilməsi və açar mübadiləsi birinci gedişdə (*1-RTT*) paralel icra olunur;
4. **Maksimal konfidensiallıq:** **ServerHello** mesajından dərhal sonra gələn bütün idarəetmə elementləri (**EncryptedExtensions**, sertifikatlar və rəqəmsal imzalar) şəbəkədə artıq şifrələnmiş şəkildə ötürülür.

5.2 Müştəri Salamı (ClientHello)

TLS 1.3 mühitində `ClientHello` mesajı müştərinin kriptografik imkanlarını göstərən genişləndirmələrə əsaslanır (Rescorla, 2018):

- **Dəstəklənən versiyalar:** Müştərinin TLS 1.3 dəstəklədiyini bildirən açıq parametr;
- **Açar payı:** Müştərinin müvəqqəti Diffi-Hellman (və ya ECDH) algoritmi üçün yaratdığı açıq açar dəyərləri;
- **İmza alqoritmləri:** Müştərinin rəqəmsal imzaları yoxlamaq üçün qəbul etdiyi heş və imza kombinasiyaları (məsələn, RSA-PSS, ECDSA).

5.3 Server Salamı (ServerHello) və Şifrəli Mesajlar

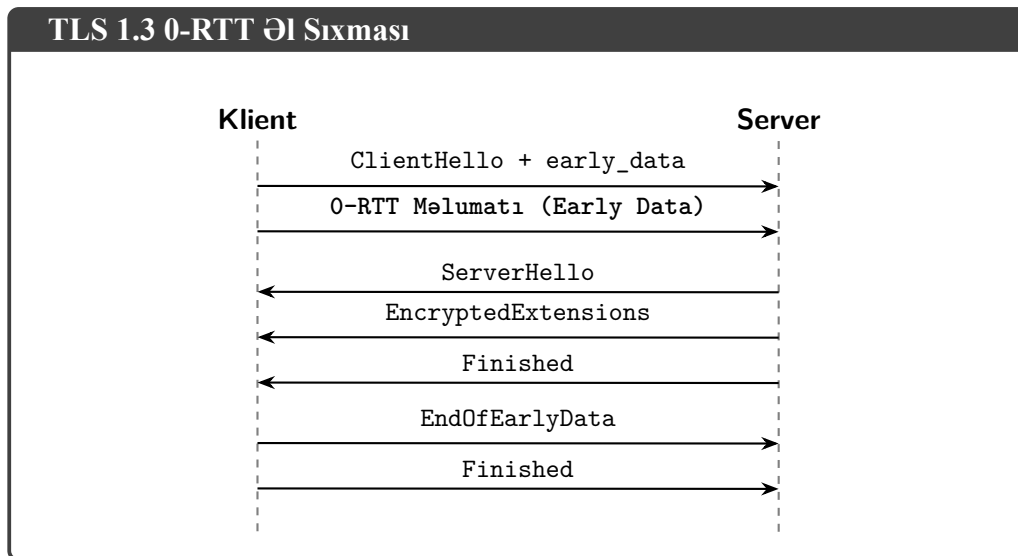
Server müştərinin təkliflərini analiz etdikdən sonra cavab mesajlarını formalaşdırır:

- **ServerHello:** Seçilmiş TLS versiyasını, unikal təsadüfi dəyəri, ortaq simmetrik şifrə dəstini və uyğun rejimdə serverin Diffi-Hellman açıq açar payını (`key_share`) ehtiva edir. Bu mesajdan sonra tərəflər əl sıxma sirrini və əl sıxma trafik sirlərini törədərək sonrakı mesajları qoruyur; əsas sirr və tətbiq trafik sirləri açar cədvəlinin sonrakı mərhələlərində törədilir;
- **EncryptedExtensions (Şifrəli Genişləndirmələr):** Serverin kriptografik xüsusiyyəti olmayan, lakin bağlantı üçün vacib olan (məsələn, ALPN, SNI cavabları) tətbiq parametrləri burada təhlükəsiz ötürülür;
- **Certificate və CertificateVerify:** Sertifikat seçilmiş identifikatorla açıq açar arasındakı sertifikat verən tərəfin iddiasını daşıyır. `CertificateVerify` isə kontekst sətiri və həmin nöqtəyədək transkript heşi daxil olmaqla müəyyən edilmiş strukturu sertifikatdakı açara uyğun gizli açarla imzalayır; müştəri ayrıca sertifikat yolunu və gözlənilən identifikatoru yoxlamalıdır;
- **Finished:** Tərəf `finished_key` ilə həmin nöqtəyədək transkript heşi üzərində HMAC hesablayıb `verify_data` göndərir. Qarşı tərəf dəyəri yenidən hesablayaraq açar cədvəlinə və transkriptə uyğunluğu yoxlayır.

6 0-RTT (Sıfır Gedış-Gəliş Müddəti) Rejimi

6.1 İş Prinsipi

0-RTT, əvvəlki sessiyadan və ya xaricdən təmin olunan əvvəlcədən paylaşılmış açar (PSK) əsasında müştərinin `ServerHello` cavabını gözləmədən `ClientHello` ilə birlikdə `early_data` göndərə bildiyi rejimdir. “0 RTT” şəbəkə gecikməsinin yox olması deyil, tətbiq məlumatını cavab gözləmədən göndərmək imkanındır; server həmin məlumatı qəbul etməyə də bilər (Rescorla, 2018).



Şəkil 4: TLS 1.3 0-RTT rejimində mesaj sırası

6.2 Kritik Təhlükəsizlik Riskləri

0-RTT bir RTT gözləmədən tətbiq məlumatı göndərməyə imkan versə də, tətbiq protokolunun ayrıca idarə etməli olduğu təhlükəsizlik kompromisləri yaradır:

1. **Təkrar Hücumları:** TLS 1.3 şəbəkədə təkrarlanmış `early_data`-nı ümumi halda aşkarlamağa zamanət vermir. Server təkrara qarşı vəziyyəti, məhdud qəbul pəncərəsi və ya tətbiq səviyyəli təkrarsızlaşdırma tətbiq etməzsə eyni əməliyyat bir neçə dəfə icra oluna bilər;
2. **İrəli Məxfilik Məhdudiyyəti:** `early_data` yalnız PSK-dan törəyən erkən sırr ilə qorunur və sonrakı (EC)DHE paylaşımına bağlı deyil. PSK sonradan əldə edilərsə və trafik qeydə alınıbsa, 0-RTT məlumatı üçün irəli məxfilik təmin edilmir;
3. **Tətbiq Semantikasi:** Metodun adı və ya HTTP metodu təkbəşinə təhlükəsizliyi göstərmir. Server hər bir əməliyyatın təkrar icrasının təsirini, autentifikasiya vəziyyətini və tətbiq protokolunun 0-RTT profilini nəzərə almalıdır.

Metodoloji tövsiyə: 0-RTT yalnız tətbiq protokolunun bunu açıq şəkildə profillədiyi, təkrarın təhlükəsiz olduğu və serverin təkrara qarşı qaydası tətbiq etdiyi əməliyyatlarda aktivləşdirilməlidir. Sadəcə GET və ya “təkrarlandıqda əlavə təsir yaratmayan” etiketi kifayət deyil: bəzi GET sorğuları yan təsir yarada, bəzi yazma əməliyyatları isə unikal təkrar açarı ilə təhlükəsiz təkrarlana bilər.

7 TLS Protokoluna Qarşı Tarixi Hücumlar və Təhlükəsizlik Problemləri

TLS/SSL protokollarının inkişaf tarixi həm də onlara qarşı edilən kriptografik və proqram təminatı səviyyəli hücumların tarixidir. Müasir TLS 1.3 protokolu məhz aşağıdakı tarixi zəifliklərin dərinəndən analiz edilməsi nəticəsində formalaşdırılmışdır.

7.1 POODLE Hücumu (2014)

POODLE birbaşa SSL 3.0 protokolunun blok şifrələmə rejimini hədəf alan boşluqdur.

Nəzəriyyəsi və İş Prinsipi:

- **Protokolun zəif versiyaya endirilməsi:** Hücümçü müştəri ilə server arasındakı müasir TLS bağlantı cəhdlərini şəbəkə səviyyəsində qəsdən kəsir və sistemləri təhlükəsizlik səviyyəsi aşağı olan SSL 3.0 protokolundan istifadə etməyə məcbur edir;
- **Doldurma sorğu mənbəyi boşluğu:** SSL 3.0 daxilindəki CBC rejimi doldurma baytlarının strukturunu dəqiq yoxlamır. Hücümçü bu boşluqdan istifadə edərək deşifrə olunmuş hər bir bayt üçün serverin verdiyi xəta cavablarını təhlil edir;
- **Nəticə:** Hücümçü sessiya çərəzlərini və şifrəli məlumatların açıq mətnini əldə edir.

Nəzəri Həlli: SSL 3.0 protokolunun infrastruktur səviyyəsində tamamilə söndürülməsi (RFC 7568).

7.2 BEAST Hücumu (2011)

BEAST hücumu TLS 1.0 versiyasında istifadə olunan CBC rejiminin tətbiqindəki zəiflikdən qaynaqlanır.

Nəzəriyyəsi və İş Prinsipi:

- TLS 1.0 protokolunda bir şifrələmə blokunun başlanğıc vektoru (IV), özündən əvvəlki blokun şifrəli mətni ilə eyni olurdu; buna görə IV ardıcıl və təxmin edilə bilən idi;
- Brauzerdə skript işlədə bilən və trafik müəşahidə edib dəyişə bilən hücümçü seçilmiş açıq mətn blokları yaradaraq təxmin edilən IV ilə gizli baytları müqayisəli şəkildə bərpa edə bilirdi. Buna görə BEAST seçilmiş-açıq-mətn hücumudur, seçilmiş-şifrəli-mətn hücumu deyil.

Nəzəri Həlli: Eksplisit (aşkar/təsadüfi) IV tətbiq edən TLS 1.1 və ya daha müasir AEAD rejimlərinə malik TLS 1.2/1.3 versiyalarına keçid.

7.3 CRIME Hücumu (2012)

CRIME hücumu TLS protokolunun nəqliyyat qatında tətbiq etdiyi sıxlaşdırma alqoritmlərinin informasiya sızdırmasına əsaslanır.

Nəzəriyyəsi və İş Prinsipi:

- DEFLATE kimi sıxlaşdırma alqoritmləri mətndə təkrarlanan ifadələri daha qısa simvollarla əvəzləyir;
- Hücümçü HTTP sorğusunun daxilində (məsələn, URL vasitəsilə) öz təxminlərini yerləşdirir. Əgər hücümçünün təxmini gizli sessiya çərəzi ilə üst-üstə düşərsə, sıxlaşdırılmış paketin ümumi ölçüsü kiçilir;
- Hücümçü paketin bayt ölçüsünün dəyişməsinə izləyərək yan kanal analizi ilə gizli məlumatları bayt-bayt bərpa edir.

Nəzəri Həlli: TLS səviyyəsində məlumatların sıxlaşdırılması funksiyasının tamamilə ləğv edilməsi.

7.4 Heartbleed Boşluğu (2014)

Heartbleed bir TLS protokolu zəifliyi deyil, dünyada ən geniş istifadə olunan OpenSSL kriptografik kitabxanasının proqramlaşdırma xətasıdır (CVE-2014-0160).

Nəzəriyyəsi və İş Prinsipi:

- TLS bağlantısının aktiv saxlanması üçün istifadə olunan Heartbeat genişləndirməsində müştəri serverə müəyyən ölçüdə məlumat göndərir və serverdən həmin məlumatı geri qaytarmasını istəyir;
- Proqram kodunda daxil olan sorğunun real ölçüsü ilə müştərinin bəyan etdiyi faydalı yük ölçüsü yoxlanılmırdı; nəticədə yaddaş sərhədindən artıq oxuma baş verirdi;
- Müştəri serverə 1 bayt məlumat göndərərək "mənə 64 KB qaytar" dedikdə, server öz operativ yaddaşından (RAM) digər istifadəçilərə aid şifrləri, gizli açarları və sessiya məlumatlarını sızdırırdı.

Nəzəri Həlli: Giriş məlumatlarının sərhədlərini ciddi şəkildə yoxlayan təhlükəsiz proqram təminatı yeniləmələrinin tətbiqi.

7.5 Logjam (2015) və FREAK (2015) Hücumları

Hər iki hücum növü protokolları daha zəif, dövlət səviyyəsində sındırıla bilən kriptografik rejimlərə keçməyə məcbur edən struktur endirmə hücumlarıdır.

Logjam Mexanizmi:

- Diffi-Hellman açar mübadiləsində istifadə olunan ortaq riyazi parametrlərin (sadə ədədlərin) ölçüsünü 512-bit kimi zəif ixrac səviyyəsinə endirir. Müasir hesablama gücləri ilə bu ölçüdə diskret loqarifmləmə problemini həll etmək və əsas açarı tapmaq mümkündür.

FREAK Mexanizmi:

- 1990-cı illərin ABŞ ixrac qanunlarına görə xarici ölkələrə zəiflədilmiş (maksimum 512-bit) RSA açarları təklif olunurdu. Hücumçu serveri bu köhnə və zəif RSA rejimini seçməyə məcbur edir və riyazi olaraq vuruqlara ayırma üsulu ilə şifrəni sındırır.

Nəzəri Həlli: Bütün köhnə ixrac səviyyəli şifrə dəstlərinin arxitekturdan silinməsi və minimum 2048-bit ölçülü asimmetrik açarlardan istifadə edilməsi.

8 Praktik Təvsiyələr

TLS konfigurasiyası üçün praktik təvsiyələr

- **Protokol versiyaları:**

- Yalnız TLS 1.2 və TLS 1.3 protokollarını dəstəkləyin.
- Təhlükəsizlik boşluqları olan SSL 2.0, SSL 3.0, TLS 1.0 və TLS 1.1 versiyalarını infrastruktur səviyyəsində tamamilə söndürün.

- **Şifrə dəstləri (*Cipher Suites*):**

- TLS 1.3 üçün standart AEAD şifrələrindən istifadə edin: AES-GCM və ChaCha20-Poly1305.
- TLS 1.2 üçün: Həm autentifikasiya, həm də məxfilik qorunması məqsədilə ECDHE + AES-GCM + SHA256 kombinasiyasına üstünlük verin.
- Müxtəlif yan kanal hücumlarına həssas olan CBC rejimli şifrələrdən tamamilə qaçın.

- **Açar mübadiləsi arxitekturası:**

- İrəli məxfilik (FS) təmin edən efemer xarakterli alqoritmlərdən (*ECDHE*, *DHE*) istifadə edin.
- Geriyə dönük deşifrə riskini aradan qaldırmaq üçün statik RSA və statik DH rejimlərindən qaçın.

- **Sertifikat idarəçiliyi:**

- Ən azı 2048-bit RSA və ya 256-bit ECC asimmetrik açar cütünə malik sertifikatlar tətbiq edin.
- Kriptoqrafik toqquşma xətlərinə görə SHA-1 imzalı köhnə sertifikatları qəbul etməyin.
- Yoxlama zəncirində qopuqluq yaşanmaması üçün sertifikat zəncirini tam şəkildə ötürün.

- **Protokol genişləndirmələri:**

- Müştəri tərəfindəki gecikmələri azaltmaq və sorğuları optimallaşdırmaq üçün OCSP bərkidilməsini aktiv edin.
- HSTS siyasətini HTTP-dən HTTPS-ə keçid zamanı `sslstrip` tipli endirməni və sertifikat xətası xəbərdarlığını keçmə davranışını azaltmaq üçün tətbiq edin; HSTS TLS versiyasının razılaşdırılmasını özü qorumur.
- TLS 1.3 0-RTT rejimini yalnız tətbiq protokolunun icazə verdiyi, təkrarın təhlükəsiz olduğu və təkrara qarşı nəzarətinin qurulduğu əməliyyatlar üçün aktivləşdirin.

- **Audit və test alətləri:**

- Kənar şəbəkədən TLS konfigurasiyasının dayanıqlığını yoxlamaq üçün SSL Labs (ssllabs.com) platformasından istifadə edin.
- Yerli və qapalı şəbəkələrdə genişmiqyaslı audit aparmaq üçün `testssl.sh` terminal aləti vasitəsilə testlər icra edin.

9 Nümunə məsələlər və çalışmaları

Cəhddən əvvəl

Əl sıxma tapşırıqlarında mesaj izi, açar vəziyyətini və qəbul/rədd qərarını özünüz işarələyin. Müəllim üçün cavab açarı yalnız ilkin cəhddən sonra açılmalıdır.

Çalışma 9.1 (1). *SSL və TLS protokolları arasındakı fundamental və kriptografik fərqləri sadalayın.*

Çalışma 9.2 (2). *Aşağıdakı TLS 1.3 izini şərh edin: ClientHello(key_share=X25519) → ServerHello(key_share=X25519) → EncryptedExtensions → Certificate → CertificateVerify → Finished. Hansı nöqtədə əl sıxma trafik sirləri yaranır, hansı mesajlar şifrələnir və server kimliyi hansı iki ayrı yoxlama ilə qəbul edilir?*

Çalışma 9.3 (3). *Bank API-si POST /transfer əməliyyatını TLS 1.3 0-RTT kimi qəbul edir; tətbiqdə unikal təkrar açarı və serverlərarası ortaqlar qarşı vəziyyəti yoxdur. Hücumçu eyni erkən məlumat yazısını iki sərhad serverinə çatdırır. Nəticəni izləyin və təhlükəsiz qəbul siyasəti təklif edin.*

Çalışma 9.4 (4). *İrəli məxfilik (FS) anlayışını izah edin və onun tətbiqinin zəruriliyini əsaslandırın.*

Çalışma 9.5 (5). *TLS 1.3 protokolunun spesifikasiyasından hansı köhnə kriptografik alqoritmlər və rejimlər çıxarılmışdır? Bunun səbəbini izah edin.*

Çalışma 9.6 (6). *Konfigurasiyada TLS_AES_128_GCM_SHA256, supported_groups=X25519 və signature_algorithms=ed25519 verilib. TLS 1.3-də bu üç parametrin müvafiq olaraq hansı funksiyaları seçdiyini və hansının sessiya açarını birbaşa ifadə etmədiyini göstərin.*

Çalışma 9.7 (7). *TLS yazı protokolunun şəbəkə qatındakı əsas funksiyalarını şərh edin.*

Çalışma 9.8 (8). *TLS/SSL protokollarına qarşı edilən tarixi hücumlardan ən azı üçünü seçərək onların riyazi və ya məntiqi əsaslarını izah edin.*

10 Müəllim üçün cavab açarı

1. SSL və TLS arasındakı fundamental fərqlər:

- **Standartlaşdırma:** SSL protokolu ilkin olaraq Netscape tərəfindən fərdi şəkildə yaradıldığı halda, TLS protokolu IETF tərəfindən beynəlxalq internet standartı olaraq sənədləşdirilmişdir;
- **Autentifikasiya mexanizmi:** TLS protokolu daha güclü mesaj autentifikasiyası üçün rəsmi HMAC alqoritmindən istifadə edir, SSL isə köhnə MAC strukturuna əsaslanır;
- **Kvadratik törəmə:** TLS daxilində gizli açarların generasiyası üçün istifadə olunan psevdo-təsadüfi funksiya (PRF) SSL-in daxili mexanizmindən daha mürəkkəb və təhlükəsizdir. TLS 1.0 SSL 3.0 bazasında hazırlansa da, aralarındakı protokol səviyyəli fərqlərə görə bir-biri ilə geriye dönük uyşumurlar.

2. TLS 1.3 iz təhlili:

- ClientHello və ServerHello açıq görünür; ikinci açar payı qəbul edildikdən sonra (EC)DHE nəticəsi və transkript əsasında əl sıxma və trafik sirləri törədilir. EncryptedExtensions və sonrakı göstərilən mesajlar qorunur.
- Sertifikat yolu/qovşaq adı yoxlaması açıq açarın gözlənilən serverə bağlanmasını, CertificateVerify isə həmin açara uyğun gizli açarın transkripti imzalamasını yoxlayır. Finished ayrıca açar cədvəli və transkript bütövlüyünü təsdiqləyir.

3. 0-RTT ssenarisinin analizi:

TLS hər iki sərhəd serverinin eyni erkən məlumatı icra etməsini ümumi halda dayandırmır; iki pul köçürməsi yarana bilər. Bu əməliyyat 0-RTT-də rədd edilməli və tam əl sıxmadan sonra göndərilməlidir. Alternativ profil yalnız tətbiq səviyyəli unikal təkrar açarı, atomik paylaşılmış təkrar nəzarəti və aydın bitmə müddəti siyasəti olduqda əsaslandırıla bilər.

4. FS anlayışı və əhəmiyyəti:

İrəli məxfilik uzunmüddətli autentifikasiya açarı sonradan kompromat olduqda belə, düzgün efemer açarların silindiyi və sessiya sirlərinin ayrıca sızmadığı fərziyyəsi altında keçmiş sessiya açarlarının bərpa olunmaması xüsusiyyətidir. TLS-də DHE/ECDHE paylaşımının açar cədvəlinə daxil edilməsi bu xüsusiyyəti verir; yalnız PSK və 0-RTT rejimləri ayrıca qiymətləndirilməlidir.

5. TLS 1.3-də çıxarılan alqoritmlər:

TLS 1.3 rekord mühafizəsində yalnız AEAD dəstlərini saxlayır; RC4 və CBC dəstləri, RSA açar ötürülməsi və statik DH açar mübadiləsi yoxdur. MD5 və SHA-1 TLS 1.3 açar cədvəli və CertificateVerify üçün istifadə edilmir. Dəyişikliklərin səbəbi yalnız hər alqoritmin “riyazi sındırılması” deyil, köhnə kombinasiya və protokol səthinin doldurma orakulu, zəif profilə endirmə və konfigurasiya risklərini azaltmaqdır.

6. Konfigurasiya artefaktı:

TLS_AES_128_GCM_SHA256 rekord üçün AEAD-i və HKDF/transkript heşini, X25519 (EC)DHE qrup/funksiyasını, ed25519 isə CertificateVerify imzasını seçir. Heç biri hazır sessiya açarının özünü göstərmir; trafik açarı və IV-lər açar cədvəli tərəfindən transkript və orta sirdən törədilir.

7. TLS Rekord Protokolunun funksiyaları:

Rekord protokolu tətbiqi qatdan gələn məlumatları qəbul edərək aşağıdakı mərhələli funksiyaları yerinə yetirir:

- **Fraqmentasiya:** Böyük həcmli məlumatları ötürülməsi rahat olan idarəolunacaq bloklara bölür;
- **Şifrələmə və Tamlıq:** Müvafiq simmetrik alqoritmlə bloku şifrələyir və ona MAC teqi və ya AEAD dolğunluğu əlavə edir;
- **Başlıq əlavə etmə:** Paketin növünü, versiyasını və ölçüsünü təyin edən TLS başlığı yerləşdirərək məlumatı nəqliyyat qatına (TCP) ötürür.

8. TLS-ə qarşı hücumların şərhı:

- **POODLE:** Şəbəkə trafikini qəsdən köhnə SSL 3.0 protokoluna endirir və CBC rejimindəki zəif dolğunlaşdırma riyaziyyatından istifadə edərək bayt-bayt məlumat sızdırır;
- **Heartbleed:** OpenSSL yaddaşının sərhədlərini yoxlamayan proqram xətasına əsaslanır. Hücumçu saxta ölçülü Heartbeat sorğusu göndərməklə serverin RAM yaddaşındakı digər gizli dataları sızdırır;
- **Logjam:** Diffi-Hellman açar mübadiləsi zamanı serveri 512-bitlik zəif ixrac parametrlərindən istifadəyə məcbur edir və riyazi olaraq əsas açarı şəbəkədə hesablayıb tapır.

11 Xülasə

Bu mühazirə çərçivəsində şəbəkə təhlükəsizliyinin əsasını təşkil edən aşağıdakı fundamental anlayışlar öyrənilmişdir:

- **TLS/SSL protokollarının təkamülü:** Netscape-in SSL ailəsindən IETF TLS 1.0, 1.1 və 1.2 versiyalarına, oradan isə sadələşdirilmiş TLS 1.3 arxitekturasına keçid təhlil edilmişdir (Rescorla, 2018).
- **TLS daxili arxitekturası:** Protokolun alt qatında yerləşən yazı protokolu ilə yuxarı funksional qat protokollarının (əl sıxma, ChangeCipherSpec, xəbərdarlıq və tətbiq məlumatları) qarşılıqlı əlaqəsi öyrənilmişdir (Stallings, 2017).
- **TLS 1.2 əl sıxması:** Əlaqənin qurulması üçün 2 RTT şəbəkə dövryyəsinin tələb olunması; ClientHello, ServerHello, Certificate, ServerKeyExchange, ClientKeyExchange, Finished mesaj ardıcılığının riyazi strukturu izah edilmişdir (Paar et al., 2024).
- **TLS 1.3 əl sıxması:** Tipik tam əl sıxmada 1 RTT arxitekturası, ClientHello daxilində efemer key_share və ServerHello-dan sonrakı əl sıxma mesajlarının qorunması mexanizmi öyrənilmişdir (Rescorla, 2018).
- **0-RTT Rejimi:** Müştərinin cavab gözləmədən erkən məlumat göndərməsi, təkrar riski, irəli-məxfilik məhdudiyyəti və tətbiq səviyyəli təkrara qarşı tələbləri analiz edilmişdir.
- **Şifrə dəstləri (Cipher Suites):** Açar mübadiləsi, rəqəmsal autentifikasiya, simmetrik şifrələmə və mesaj tamlığının qorunması məqsədilə istifadə olunan kriptografik blokların idarə edilməsi prinsipləri öyrənilmişdir (Ferguson et al., 2010).
- **İrəli məxfilik (FS):** Uzunmüddətli asimmetrik açarların gələcəkdə ələ keçirilməsi riskinə qarşı tarixi sessiya məlumatlarının təhlükəsizliyini təmin edən efemer kəsilməzlik arxitekturası tədqiq edilmişdir (Diffie and Hellman, 1976).

- **Tarixi zəifliklər və boşluqlar:** Protokolların tətbiqində ortaya çıxan POODLE, BEAST, CRIME, Heartbleed, Logjam və FREAK kimi kriptografik və proqram səviyyəli hücum metodları araşdırılmışdır.

Əsas nəticə: TLS 1.3 köhnə şifrə dəstlərini və açar mübadiləsi rejimlərini azaldır, lakin təhlükəsizlik yenə də seçilmiş rejimdən və tətbiq siyasətindən asılıdır. Tam (EC)DHE əl sıxması və psk_dhe_ke tətbiq məlumatına irəli məxfilik verə bilər; psk_ke və 0-RTT üçün bu təminat yoxdur. Təhlükəsiz istismar protokol versiyası, alqoritm siyasəti, sertifikat yoxlaması, 0-RTT semantikasi və HTTP səviyyəli HSTS kimi nəzarətlərin birlikdə düzgün qurulmasını tələb edir.

References

- W. Diffie and M. E. Hellman. New directions in cryptography. *IEEE Transactions on Information Theory*, 22(6):644–654, November 1976. doi: 10.1109/TIT.1976.1055638.
- N. Ferguson, B. Schneier, and T. Kohno. *Cryptography Engineering: Design Principles and Practical Applications*. Wiley, Indianapolis, 2010. ISBN: 978-0470474242.
- C. Paar, J. Pelzl, and T. Güneysu. *Understanding Cryptography: A Textbook for Students and Practitioners*. Springer, Berlin, Heidelberg, 2nd edition, 2024. ISBN 978-3-662-68393-4. doi: 10.1007/978-3-662-68394-1.
- E. Rescorla. The transport layer security (tls) protocol version 1.3, August 2018. <https://www.rfc-editor.org/info/rfc8446>.
- W. Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7 edition, 2017.
- D. R. Stinson and M. B. Paterson. *Cryptography: Theory and Practice*. CRC Press, Boca Raton, 4th edition, 2018. ISBN: 978-1138197015.